

INTERNAL SECURITY AUDIT

Stakeholder Summary

Botium Toys

Plain English review of controls, compliance, and recommended next steps

Prepared by Joseph Guidici

May 6, 2026

Confidential. For internal stakeholders only.

Executive Summary

Botium Toys is growing fast, and the company's online presence has grown with it. That growth has outpaced the security and compliance work needed to protect customers and the business. To get ahead of it, the IT manager asked for an internal audit to take an honest look at where things stand.

This document is the plain English version of that audit. It is written for leadership and other non technical stakeholders who need to understand the risks, the wins, and what to do next without wading through a checklist.

The bottom line:

- There are real strengths to build on. Physical security, antivirus, the firewall, and the breach notification plan are all working as they should.
- There are also serious gaps. Credit card data is not encrypted, every employee can see customer information, and there is no plan for recovering from a disaster or detecting an intruder.
- The most urgent issues sit inside payment card protection (PCI DSS). Until those are addressed, the company is carrying meaningful financial, legal, and reputational risk.

None of this is unfixable. Most of the high impact work is straightforward, and the recommendations later in this document are organized so leadership can decide what to tackle first.

What We Looked At

Scope

The audit covered the entire security program at Botium Toys. Nothing was carved out. That includes how data is stored, who can see it, how systems are protected, and how the company would respond if something went wrong.

Goals

Two things were measured:

- Are the right security controls in place and actually working?
- Is the company meeting the compliance standards it needs to meet, specifically PCI DSS, GDPR, and SOC type 1 and 2?

How the audit was done

1. Reviewed the asset inventory to understand what the company has and what it depends on.
2. Walked through a controls checklist covering technical, administrative, and physical safeguards.
3. Worked through compliance checklists for PCI DSS, GDPR, and SOC type 1 and 2.
4. Translated the findings into recommendations leadership can act on.

The Big Picture

What is working well

These are real wins and worth calling out. They show the company already takes some parts of security seriously.

- The physical side of the business is solid. Locks, surveillance, and fire prevention are all functioning.
- Antivirus is installed and actively monitored on company devices.
- The network perimeter has a properly configured firewall.
- There is a documented plan to notify EU customers within 72 hours of a breach, which is a GDPR requirement.
- Data is properly classified, inventoried, and managed under enforced privacy policies.

Where the real risk is

These are the issues that should keep leadership up at night. They cluster into three themes.

1. Anyone can see anything.

Today, every employee at Botium Toys can access every piece of customer data, including credit card information. That is the root cause of most of the failed compliance items in this report. Industry standards exist precisely to prevent this.

2. Sensitive data is not protected.

Credit card information is stored on an internal database without encryption. If someone got into that system, the data would be readable on its face. There is also no intrusion detection system watching for that kind of access in the first place.

3. There is no safety net.

Critical data is not being backed up, and the company has no disaster recovery plan. A ransomware attack, hardware failure, or even a human mistake could result in permanent loss of business critical information.

Controls Snapshot

This is a one page view of the controls reviewed during the audit. “In place” means the control is working. “Gap” means it needs to be addressed.

Area	Status	Notes
Least privilege access	Gap	Every employee can see customer data, including people who do not need it for their job.
Disaster recovery plan	Gap	There is no written plan for getting systems back up after an outage or attack.
Password policy	Gap	A policy exists on paper but does not require strong passwords.
Separation of duties	Gap	Single individuals can perform sensitive tasks end to end with no second set of eyes.
Firewall	In place	Configured appropriately and protecting the network perimeter.
Intrusion detection (IDS)	Gap	No system is watching for suspicious activity inside the network.
Data backups	Gap	Critical business data is not being backed up. A single failure could cause permanent loss.
Antivirus software	In place	Installed and actively monitored on company devices.
Legacy system maintenance	Gap	Older systems are not on a regular patch or check-in schedule.
Encryption of sensitive data	Gap	Credit card information is stored without encryption, leaving it exposed if accessed.
Password management system	Gap	No tool is enforcing minimum password requirements across the company.
Physical locks	In place	Offices, storefront, and warehouse are physically secured.
CCTV surveillance	In place	Up to date and covering the relevant locations.
Fire detection and prevention	In place	Alarms and sprinklers are functioning correctly.

Compliance Status

PCI DSS (payment card protection)

This standard applies because Botium Toys handles credit card information. It is the area with the largest gap, and getting this right should be the first priority. Failing PCI DSS can mean fines, increased transaction fees, and in some cases losing the ability to accept card payments altogether.

Area	Status	Notes
Only authorized users access credit card data	Gap	Currently every employee can access this information.
Card data stored and processed in a secure environment	Gap	Data sits on a local internal database without sufficient protection.
Encryption at credit card touchpoints	Gap	No encryption is applied to payment card data.
Secure password management policies	Gap	No managed policy is in place.

GDPR (EU customer privacy)

Because Botium Toys does business in the European Union, GDPR applies. The breach notification plan, classification, and policy enforcement all check out. The remaining gap is the same access issue that affects everything else: too many people can see customer data.

Area	Status	Notes
EU customer data is kept private and secure	Gap	All employees can access EU customer records.
72 hour breach notification plan	In place	A documented plan exists for notifying customers within 72 hours.
Data is properly classified and inventoried	In place	Data is organized and stored as required.
Privacy policies and procedures enforced	In place	Documented and well enforced.

SOC type 1 and SOC type 2

SOC reports are how a company demonstrates to partners, auditors, and customers that it manages data responsibly. Data integrity and availability look strong. The same access control issues hold the company back here too.

Area	Status	Notes
User access policies are established	Gap	Access is open to all staff today.
Sensitive data (PII / SPII) is kept private	Gap	All employees can access customer PII and SPII.
Data integrity is maintained	In place	IT confirms data is consistent, complete, and validated.
Data is available to authorized users	In place	IT ensures availability for those who need it.

Recommendations

These are sorted so leadership can see what to do first. The order reflects both impact and how exposed the business is today.

Tier 1: Address now

These items reduce the largest, most immediate risks. Together they bring the company much closer to PCI DSS compliance.

- Restrict access to credit card data and customer PII. Only the roles that actually need this information should be able to see it.
- Encrypt credit card information at rest and in transit. This is a non-negotiable PCI DSS requirement.
- Implement a password management system that enforces strong, unique passwords across the company.
- Stand up data backups for all critical systems. Test the restore process so it works when it is needed.

Tier 2: Build the safety net

These items make the business resilient and bring detection capabilities online.

- Deploy an intrusion detection system so suspicious activity inside the network is actually noticed.
- Document and rehearse a disaster recovery plan so the company knows exactly what to do if systems go down.
- Introduce separation of duties for sensitive workflows so no single person can complete a high-risk action alone.

Tier 3: Strengthen the everyday

These items raise the security baseline and reduce slow burning risks over time.

- Put legacy systems on a regular maintenance and patching schedule.
- Move existing password policy from “written down” to “actually enforced” in every application.
- Review access permissions on a recurring basis so they keep matching what people actually do.

Suggested Next Steps

To turn this report into action, we suggest the following.

1. Assign an owner for each Tier 1 item with a target completion date inside the next quarter.
2. Build a simple project plan for PCI DSS remediation. Treat it as a single workstream rather than a list of unrelated fixes.
3. Schedule a follow up review in 90 days to confirm progress and adjust priorities.
4. Plan for a longer-term cadence of internal audits, ideally once or twice a year, so the company never drifts this far again.

Questions or feedback on this report can be directed to Joseph Guidici.